

Cyber Security - Cyber Security Posture Statement

1. Introduction

1.1 Background

The security of APM's data and assets is fundamental to its ability to meet its business objectives, fulfill its obligations, manage risks, and maintain the trust of its customers and business partners. This statement contains general information regarding the IT security measures in place within APM.

1.2 Purpose

The primary purpose of the Cyber Security Posture Statement (CSPS) is to provide Advanced Personnel Management's (APM's) customers with a high-level overview of the Information Technology (IT) security controls in place within the APM Information Communication and Technology (ICT) environment, and assurance in APM's cyber security practices.

2. Operational Security

2.1 Cyber Security Governance

APM has clearly defined information security roles and responsibilities for employees who interact with Personal Identifiable Information (PII). The scope of personnel includes APM's board of members, senior management, and individual personnel who approve, oversee, and make decisions guarding PII and other sensitive information.

2.2 Cyber Security Strategy

To ensure APM manages PII data and other sensitive information, APM went through a rigorous process to obtain a successful compliance against International Standard Organisation (ISO) 27001:2022 and the Department of Employment and Workplace Relations' (DEWR's) Right-Fit-for-Risk (RFFR) certification that ensures APM is complying to strict guidelines set by DEWR to store, manage and modify OFFICIAL: *Sensitive* data. All RFFR compliant technology policies, standards and IT Infrastructure procedures are used across all APM centrally managed APAC Group businesses.

APM has implemented IT security controls in its environment to protect its systems, data, assets, and the organisation's reputation from security, privacy, and operational risks. APM has established, and actively maintains, an organisational Risk Management Framework (RMF). This was developed around APM's strategy, business plans, and the desired level of risk that the organisation is willing to take. APM performs risk assessments according to its RMF and determines appropriate controls to reduce the level of risk faced by APM, throughout its operations.

2.3 Compliance

APM is committed to complying with all applicable laws, regulations, and contractual requirements in all its operations. APM informs and/or seeks assistance from Australian Cyber Security Centre (ACSC) when a cyber security incident has occurred within APM ICT system.

APM performs internal and external audits of its environment annually to maintain the certifications that it holds.

2.4 Third Party Security

Third parties are required to agree to Cyber Security - Security Standards for Third Parties Engaging with APM Policy and *APM Information Security Code of Practice* prior to gaining access to its systems.

All third-party contracts are overseen by APM's legal department to ensure that appropriate due diligence is performed prior to the contract being signed.

2.5 Incident Response

APM possesses and maintains a *Cyber Security Incident Response Plan*, *Disaster Recovery Plan*, and Business Continuity Plan that outline its capability to identify and resolve incidents.

To allow it to respond to incidents effectively, APM has established an incident management process, that provides guidance to personnel when identifying and resolving incidents.

The DRP and BCP are tested on an annual basis, to ensure that the activities within the plan allow APM to effectively recover.

To ensure that APM responds appropriately to the changing nature of the cyber security threats that may target it, the incident response activities are reviewed to ensure that they operate effectively and allow APM to recover in a timely manner.

3. Personnel Security

3.1 Hiring

Prior to offering employment to candidates, APM performs the following checks:

- Identification – To establish and confirm the candidate's identity.
- Australian Federal Police Clearance – To conduct a criminal history check on APM interviewed candidates to ensure that the employees will maintain confidentiality, integrity and availability of data hosted within APM ICT networked environment.
- Employment Reference – To confirm employment history.
- Academic Reference – To confirm the existence of the applicant's academic qualifications.
- Visa or Citizenship – to confirm that the candidate holds sufficient working rights within Australia.

As part of the standard employee contract, all personnel are required to sign a confidentiality agreement and abide by APM's defined policies and procedures.

3.2 Ongoing Employee Training & Assessment

APM personnel are required to undergo privacy and information security awareness training modules as part of their onboarding, and then annually thereafter. Due to the importance of these training modules, personnel who fail to complete them in a timely manner may face disciplinary actions.

The training undertaken by APM personnel includes, but is not limited to:

- Passphrase security requirements – aligned to the requirements.
- Information collection and security requirements.
- Information security threats, risks, and appropriate actions to be undertaken in the event of an incident.
- The obligations that personnel have toward information security.

The training provided within APM is further supported through internal testing and monitoring to determine the effectiveness and uptake of the training provided to personnel.

3.3 Resignation/Termination

Staff access to APM ICT system is terminated and APM owned assets are returned on their last day of employment to prevent unauthorised access to APM systems.

4. Physical Security

4.1 APM Premises

APM holds compliance against ISO 27001:2022 and requires all onsite APM operations are conducted within an APM owned and/or leased building, with a defined security perimeter.

Physical documentation is stored within locked cabinets when not in use, clear desk and screen policy is enforced through the *APM Information Security Code of Practice*.

4.2 Data Centres

All data held by APM APAC centrally managed entities on APM managed infrastructure and systems is stored within Microsoft's Australian Azure cloud services, with the data centre locations being Sydney and Melbourne. These data centres are compliant against ISO 27001:2022, and Service Organisation Control (SOC) Type 2 certifications.

4.3 Enterprise Asset Management

Labels are affixed to physical assets that display APM's name, and the number for the ICT service desk to arrange return of the asset, if it were ever to be lost. Requests to remove APM assets from site must be reviewed and approved by Office Managers, or the Operations Team Lead, prior to the asset being removed from APM sites. Access to removable media is administratively disabled on APM ICT assets. An explicit approval needs to be granted by APM ICT stakeholder(s) to allow accessing of APM approved removable media.

5. Information Security

5.1 Information Policies and Standards

APM maintains a series of information security policies and standards. Some of these high-level policies are as follows:

- An *Information Security Policy* that provides APM's overarching security requirements.
- An *Information Security Code of Practice*, that contains APM's information security requirements for all external and internal personnel that access its network.
- Information security standards exist that define how the organisation's controls are implemented, to meet the intent of its policies.
- Information security processes exist that provide further guidance to personnel.

APM's *Information Security Policy* and, further information regarding Standard and process contents can be provided upon request.

5.2 Identity and Access Management

APM has implemented specialised Identity and Access Management (IAM) controls to prevent unauthorised access to its assets or systems, which are configured to align to APM's Identity *and IT Access Management Standard*. This policy describes:

- Multi-factor authentication.
- Complex passwords, aligned to the ISM requirements.
- Session termination based on inactivity.

All users are granted access to information and systems based on the requirements of their role and using the principles of need-to-know and least-privilege.

5.3 Information Asset Management

To maintain APM's assets throughout their lifecycles, all assets are:

09.01.033-5.0	Owner: CISO	Publish Date: 02/07/2026	Classification: Internal	Page 3 of 5
---------------	-------------	--------------------------	--------------------------	-------------

- Recorded within APM's IT Service Management solution.
- Classified according to the Information Technology - *Information Asset Classification & Handling Standard*.
- Securely disposed of as per the Information Technology – *IT Asset Management Standard*.

5.4 Information Backup

APM performs information and system backup activities at a regular cadence to meet the requirements stipulated within the *Information Systems Backup and Archiving Standard*, that defines the Recovery Time Objectives and Recovery Point Objectives for its systems.

5.5 Cryptography

Cryptographic technology is widely used throughout APM to protect its electronic information. APM has implemented cryptographic controls aligned with the Australian Signals Directorate (ASD) approved cryptographic algorithms (AACA)¹ for information in transit, and at rest. This includes data that is stored within removable media.

5.6 Anti-Malware

APM utilises a multilayer approach to malware detection and prevention. APM has network and host-based antimalware solution(s).

5.7 Vulnerability Management

APM's assets are scanned on a regular cadence to identify any vulnerabilities that may exist and are managed by using a risk-based vulnerability management process. This is defined within the *Patch and Vulnerability Management Standard* and requires identified and assessed vulnerabilities to be remediated. Remediation must be conducted in accordance with the criticality of the identified vulnerability, aligned to the vulnerability management requirements within the ISM.

5.8 Penetration Testing

APM's Information Security team undertake a formalised technical assurance program including annual Penetration Testing of all key systems and infrastructure. Penetration testing is also conducted prior to go live of new services and for any significant updates. Executive summaries of these reports are able to be provided to customers with regards to the systems that make up their services.

6. Communication Security

6.1 Network Security

APM ensures the assets within its network remain protected from malicious activities using technical controls including perimeter firewalls, secure web gateway clients, and intrusion detection and prevention systems. All notifications produced from these devices are monitored by APM's Secure Operations Centre (SOC), to ensure swift response to alerts.

APM's wireless network devices are configured to require personnel to authenticate to the organisation's network, prior to being provided access.

¹ <https://www.cyber.gov.au/acsc/view-all-content/guidance/asd-approved-cryptographic-algorithms>

6.2 Remote Access

All remote access to the APM network requires access to APM's Virtual Private Network, or approval to use its Virtual Desktop Infrastructure. These services are monitored during use, and all connections are encrypted to maintain the confidentiality of data.

7. Related Legislation or Document

- APM - Risk Management Framework
- Cyber Security Incident Response Plan
- Disaster Recovery Plan
- Identity and IT Access Management Standard
- Information Asset Classification & Handling Standard
- Information Security Code of Practice
- Information Security Policy
- Information Systems Backup and Archiving Standard
- IT Asset Management Standard
- Patch and Vulnerability Management Standard
- Security Standards for Third Parties Engaging with APM Policy

8. Review

Update this document whenever requirements change and review at least once a year.